



Executive Summary



Executive Summary

Our security review identified urgent risks in Xibalba's infrastructure ahead of your player stats site launch. Most critically, an unsecured development server has exposed your game's source code—this not only puts your competitive edge at risk but invites attackers to exploit weaknesses in live systems. Equally concerning is a stored XSS vulnerability in the stats platform itself, which could let hackers inject malicious code to hijack player accounts, steal data, or spread malware. Compounding these issues are risky practices like reusing database passwords across test/live environments, leaving admin tools online without multi-factor authentication, and a misconfigured VPN granting insecure access to test servers. Your monitoring also has gaps: while network and login activity is tracked, critical server-level processes and account changes aren't centralized in your SIEM system, creating blind spots. Current alerts focus too narrowly on gaming/payment servers, leaving other systems (like the new site) under-defended. Given that many U.S. government employees use your games, these flaws could escalate beyond brand damage—compromised player accounts might become gateways for targeting government networks. Addressing these gaps immediately is vital to protect both your business and users. Delaying fixes risks costly breaches, eroded trust, and regulatory scrutiny, especially with sensitive player data at stake.

Honeypot Solutions

- Network Honeypot: Critical for detecting early-stage attacks (e.g., lateral movement) and mapping attacker behavior in decoy environments.
- Credential Honeypot: Prioritized to intercept stolen credential reuse, a common tactic in breaches.

2. Data Sources

- Command Execution Honeypot (DS0017): Reveals attacker tactics by logging malicious command-line activity (e.g., ransomware deployment).
- File Modification Honeypot (DS0022): Detects unauthorized tampering with critical files (e.g., config/data destruction).

3. Mitigation Strategies

- M1036: Account Use Policies: Enforce multi-factor authentication (MFA) and strong passwords to reduce account compromise risks.
- M1041: Encrypt Sensitive Information: Protects data integrity even if attackers bypass other defenses.





Threat Model for Xibalba Interactive



Threat Actors



Threat Actors

1. APT

APTs (often state-backed hackers) matter here because they hunt high-value targets like payment data and government-linked info. They slip in through weak VPNs and reused passwords, then lurk in systems to steal financial intel—perfect for spying or setting up bigger attacks, like targeting officials through stolen details.

- **SCENARIO:**

Attackers breach the misconfigured dev VPN, use shared database credentials to pivot into production gaming servers, and exfiltrate player payment data.

2. Cybercriminals

Cybercriminals prioritize fast financial gains, and this scenario presents a significant opportunity for them. A misconfigured Apache server with an exposed .git folder creates an easily exploitable vulnerability. Attackers could steal proprietary game code, sell it to competitors, or develop unauthorized cheat systems. This type of breach not only results in theft but also directly harms the company's revenue and public trust. These threat actors rely on overlooked security weaknesses rather than advanced tools, and this configuration error provides a straightforward path for exploitation.

- **SCENARIO: Attackers exploit the misconfigured Apache server on dev.xibalbainteractive.com, accessing the exposed .git folder to download proprietary game source code and reverse-engineer intellectual property.**

3. THREAT ACTOR

State-sponsored hackers target situations like this by compromising trusted updates to bypass security and spy on government communications. Their goal isn't quick cash, but stealing secrets. Intercepting messages can lead to blackmail, espionage, or access to government systems. This is a calculated, resource-driven attack typical of nation-states.

- **SCENARIO: A compromised vendor update injects malware into the game client, bypassing end-to-end encryption to intercept and exfiltrate private chats of government employee teams.**



Attack Surface

Attack Surface

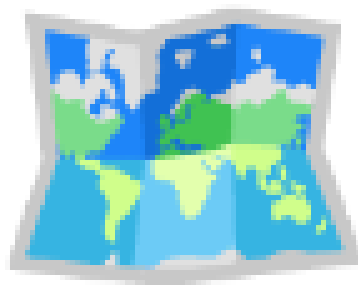
 Attack Surface	1
.git hub.....	1
Game source code.....	1
VPN software.....	1
Developer workstation.....	1
Game servers.....	1
Game developers.....	1
Gamers.....	1
chat system.....	1
Physical servers.....	2
Administrators.....	2
Shared production PCI credentials.....	2
User profiles.....	2
Comments that may include PII.....	2

Attack Surface	Asset(s)	ATT&CK TTPs	Likelihood	Impact
.git hub.	Intellectual property (IP)	T1078: Valid Accounts	3 (Pos... ▾)	4 (Major) ▾
Game source code.	Intellectual property (IP)	T1565.001: Stored Data Manipulation	3 (Pos... ▾)	4 (Major) ▾
VPN software.	Intellectual property (IP)	T1078: Valid Accounts	5 (Alm... ▾)	5 (Cata... ▾)
Developer workstation.	Intellectual property (IP)	T1195: Supply Chain Compromise	3 (Pos... ▾)	4 (Major) ▾
Game servers.	Intellectual property (IP)	T1190: Exploit Public-Facing Application	4 (Like... ▾)	4 (Major) ▾
Game developers.	Intellectual property (IP)	T1213: Data from Information Repositories	5 (Alm... ▾)	5 (Cata... ▾)
Gamers.	In-game private chat system	T1566: Phishing	5 (Alm... ▾)	5 (Cata... ▾)
chat system.	In-game private chat system	T1040: Network Sniffing	4 (Like... ▾)	4 (Major) ▾

Attack Surface	Asset(s)	ATT&CK TTPs	Likelihood	Impact
Physical servers.	Payment information (PCI)	● T1078: Valid Accounts	4 (Like... ▾)	4 (Major) ▾
Administrators.	Payment information (PCI)	● T1078: Valid Accounts	4 (Like... ▾)	4 (Major) ▾
Shared production PCI credentials.	Payment information (PCI)	● T1078: Valid Accounts	4 (Like... ▾)	4 (Major) ▾
User profiles.	Personally identifiable Information (PII)	● T1530: Data from Cloud Storage	4 (Like... ▾)	4 (Major) ▾
Comments that may include PII.	Personally identifiable Information (PII)	● T1213: Data from Information Repositories	4 (Like... ▾)	3 (Mod... ▾)



Solution Roadmap



Solution Roadmap for Xibalba Interactive

Honey strategies



Honey strategy Solutions:

Honey strategy Solutions:	1
Network Honeypot	2
STAKEHOLDERS	2
Executives	2
IT Team	2
Legal	2
GOALS	2
Deploy network traffic decoys	2
Create honeypot network shares	3
Implement network service traps	3
Email/Phishing Honeypot	3
STAKEHOLDERS	3
Executives	3
IT Team	3
Legal	3
GOALS	3
Deploy decoy email accounts	4
Implement document traps	4
Build a phishing intelligence database	4
Credential Honeypot	4
STAKEHOLDERS	4
Executives	4
IT Team	4
Legal	4
GOALS	4
Deployment of decoy credentials	5
Integration with SIEM	5
Attacker behavior analysis	5
Data Repository Honeypot	5
STAKEHOLDERS	5
Executives	5
IT Team	5
Legal	5
GOALS	5
Deploy database honeypots	5
Implement cloud storage decoys	6
Create document repository traps	6



Honeycomb Solution #1

Network Honeypot.	Difficulty: 2 (Medium) ▾	Priority: 2 (Medium) ▾
A strategic deployment of decoy network services, traffic generators, and monitored network shares designed to detect unauthorized network monitoring and lateral movement. This solution creates deliberate network targets that generate alerts when probed or accessed, providing early warning of network reconnaissance and traffic interception.		
Addresses attack vector(s):	- T1040: (Network Sniffing)- T1046: (Network Service Scanning)- T1135: (Network Share Discovery)- T1557: (Man-in-the-Middle)	
Protects key asset(s):	- Internal network communications- Sensitive network traffic- Network file shares- Unencrypted data in transit- Server-to-server communications	
STAKEHOLDERS		
Executives	IT Team	Legal
Provides visibility into stealthy reconnaissance activities that often precede major breaches. Demonstrates proactive security approach for board reporting. It helps quantify previously invisible threat activity.	Detects attackers during early reconnaissance phases before damage occurs. Provides valuable data on attacker movement patterns and techniques. Creates opportunities to contain threats before lateral movement.	Strengthens evidence collection for potential legal actions. Supports compliance requirements for network monitoring. Demonstrates reasonable protection measures for sensitive communications.
GOALS		
Name	Description	Deadline
Deploy network traffic decoys	Implement systems that generate realistic-looking traffic containing monitored fake sensitive data to detect sniffing	9 Months
Create honeypot network shares	Deploy monitored network shares with enticing file names and fake sensitive content across key network segments	6 Months
Implement network service traps	Set up decoy network services (databases, file servers, etc.) that log and alert on connection	6 Months

	attempts	
--	----------	--

Honeypot Solution #2

Email/Phishing Honeypot.	Difficulty: 1 (Easy) ▾	Priority: 3 (High) ▾
A comprehensive deployment of decoy email accounts monitored document links, and fake intranet portals designed to detect phishing campaigns targeting the organization. This solution creates deliberate phishing targets that generate alerts when accessed, providing early detection of social engineering attempts and enabling rapid response to emerging threats.		
Addresses attack vector(s):	- T1566: Phishing- T1566.001: Spearphishing Attachment- T1566.002: Spearphishing Link- T1566.003: Spearphishing via Service	
Protects key asset(s):	- Employee email accounts- Corporate intranet resources- Sensitive document repositories- Authentication credentials- Customer data systems	
STAKEHOLDERS		
Executives	IT Team	Legal
Reduces risk of business email compromise (BEC) attacks targeting leadership. Provides measurable metrics on phishing attempts for security investment decisions. Demonstrates proactive defense against the most common initial access vector..	Enables early warning of targeted campaigns before widespread impact. Provides valuable threat intelligence on attacker TTPs and targeting priorities. Reduces incident response time through automated detection.	It supports regulatory compliance for data protection laws, provides evidence of security due diligence, and helps establish the legal foundation for potential actions against identified threat actors.
GOALS		
Name	Description	Deadline
Deploy decoy email accounts	Create monitored honeypot email accounts with realistic personas at various organizational levels with alerting on received messages and access attempts	6 Months
Implement document traps	Deploy fake sensitive documents with tracking capabilities to	6 Months

	detect access and exfiltration attempts	
Build a phishing intelligence database	Develop a system to catalog phishing attempts, techniques, and indicators for improved detection and prevention	9 Months

🏰 Honeypot Solution #3		
Credential Honeypot	Difficulty: 1 (Easy) ▾	Priority: 2 (Medium) ▾
A strategic deployment of decoy user accounts, password files, and authentication systems designed to detect unauthorized access attempts. This solution creates monitored credential traps that generate alerts when accessed, providing early warning of credential theft or abuse attempts across our systems.		
Addresses attack vector(s):	- T1078: Valid Accounts- T1552: Unsecured Credentials- T1110: Brute Force	
Protects key asset(s):	- User authentication systems- Administrative access portals- Database credential stores- Cloud service accounts- API authentication tokens	
STAKEHOLDERS		
Executives	IT Team	Legal
Catches stolen passwords before hackers can cause costly damage. Shows board members we're staying ahead of threats.	Reveals how attackers try to steal passwords, helping us build better defenses. Speeds up investigations by documenting hacker methods.	Helps meet compliance rules while proving we're serious about protecting sensitive information..
GOALS		
Name	Description	Deadline
Deployment of decoy credentials	Create and deploy monitored credentials across critical systems (admin portals, file shares, databases) with alerting on access attempts	6 Months
Integration with SIEM	Ensure all honeypot alerts are properly integrated with security monitoring systems for	6 Months

	immediate response	
Attacker behavior analysis	Develop analysis framework to categorize and study attacker behavior when interacting with credential honeypots	9 Months

👑 Honeypot Solution #4		
Data Repository Honeypot	Difficulty: 2 (Medium) ▾	Priority: 3 (High) ▾
Fake databases, cloud storage, and document repositories filled with monitored decoy data. Creates attractive targets that alert us when accessed, catching data thieves early before they reach real information.		
Addresses attack vector(s):	- T1213: Data from Information Repositories- T1530: Data from Cloud Storage- T1565.001: Stored Data Manipulation	
Protects key asset(s):	- Customer databases- Financial records- Intellectual property documents- Cloud storage buckets- Internal knowledge bases	
STAKEHOLDERS		
Executives	IT Team	Legal
Catches data thieves before they can steal valuable information. Shows board members we're staying ahead of threats.	Reveals how attackers target our data, helping us build better defenses. Speeds up investigations by documenting hacker methods.	Helps meet compliance rules while proving we're serious about protecting sensitive information.
GOALS		
Name	Description	Deadline
Deploy database honeypots	Create fake database servers with monitored tables containing synthetic customer and financial data	6 Months
Implement cloud storage decoys	Set up monitored cloud storage buckets with fake sensitive files and access logging	6 Months

Create document repository traps	Deploy decoy document management systems with monitored fake intellectual property and internal documentation	9 Months
---	---	----------



Data sources



Data Sources:

 Data Sources:	1
User Account Authentication Honeypot (DS0002).....	2
STAKEHOLDERS.....	2
Executives.....	2
IT Team.....	2
Legal.....	2
GOALS.....	2
IMPLEMENT EARLY WARNING SYSTEM.....	2
ESTABLISH BASELINE THREAT INTELLIGENCE.....	3
INTEGRATE WITH SECURITY RESPONSE.....	3
Application Log Honeypot (DS0015).....	3
STAKEHOLDERS.....	3
Executives.....	3
IT Team.....	3
Legal.....	3
GOALS.....	3
CREATE CONVINCING DECOY REPOSITORIES.....	3
MONITOR UNAUTHORIZED ACCESS.....	4
ANALYZE ATTACKER BEHAVIOR.....	4
Command Execution Honeypot (DS0017).....	4
STAKEHOLDERS.....	4
Executives.....	4
IT Team.....	4
Legal.....	4
GOALS.....	4
DEPLOY CONVINCING SERVER ENVIRONMENT.....	4
CAPTURE COMPLETE ATTACK SEQUENCES.....	5
GENERATE ACTIONABLE INTELLIGENCE.....	5
File Modification Honeypot (DS0022).....	5
STAKEHOLDERS.....	5
Executives.....	5
IT Team.....	5
Legal.....	5
GOALS.....	5
DEPLOY STRATEGIC FILE HONEYPOTS.....	5
ESTABLISH REAL-TIME MONITORING.....	6

 Data Source Solution #1		
User Account Authentication Honeypot (DS0002)	Difficulty: 1 (Easy) ▾	Priority: 1 (Low) ▾
Deploy decoy user accounts across authentication systems that appear legitimate but are never used by actual users, allowing for reliable detection of unauthorized access attempts.		
Addresses attack vector(s):	- T1078: Valid Accounts- T1110: Brute Force- T1556: Modify Authentication Process- T1557: Man-in-the-Middle	
STAKEHOLDERS		
Executives	IT Team	Legal
The implementation provides measurable security metrics on attempted breaches with minimal operational disruption. Demonstrates proactive security posture to board members and investors.	Deployment creates minimal additional overhead while providing valuable intelligence on credential attacks. Helps identify compromised credentials before they impact production systems.	Establishes clear evidence of unauthorized access attempts for potential legal action. Documentation of attack patterns strengthens regulatory compliance reporting.
GOALS		
Name	Description	Deadline
IMPLEMENT EARLY WARNING SYSTEM	Deploy at least 10 honeypot accounts across 3 critical systems that trigger alerts within 5 minutes of any authentication attempt, with zero false positives.	6 Months
ESTABLISH BASELINE THREAT INTELLIGENCE	Collect and analyze authentication attack patterns over 90 days to identify common attack sources, and techniques, and improve existing security controls.	9 Months
INTEGRATE WITH SECURITY RESPONSE	Connect honeypot alerts to automated security response workflows that immediately isolate potentially compromised	9 Months.

	systems and trigger investigation protocols.	
--	--	--

 Data Source Solution #2		
Application Log Honeypot (DS0015)	Difficulty: 2 (Medium) ▾	Priority: 2 (Medium) ▾
Deploy fake application logs containing seemingly valuable information (credentials, API keys, session data) that appear authentic but are monitored for unauthorized access to detect attackers searching for sensitive information.		
Addresses attack vector(s):	- T1005: Data from Local System- T1039: Data from Network Shared Drive- T1213: Data from Information Repositories- T1552: Unsecured Credentials	
STAKEHOLDERS		
Executives	IT Team	Legal
Log honeypots reveal hidden internal threats and lateral movement while providing measurable metrics to demonstrate our threat-hunting effectiveness.	The implementation leverages existing logging infrastructure with minimal modification. Provides valuable insights into attacker behaviors once inside the network.	Creates a documented chain of evidence for potential insider threats and external breaches. Strengthens legal position by demonstrating reasonable security measures.
GOALS		
Name	Description	Deadline
CREATE CONVINCING DECOY REPOSITORIES	Develop and deploy at least 5 realistic log honeypots containing convincing but fake sensitive data across critical application environments.	6 Months
MONITOR UNAUTHORIZED ACCESS	Implement monitoring systems that can detect and alert on any access to honeypot logs within 15 minutes, with detailed activity logging for forensic analysis.	6 Months
ANALYZE ATTACKER BEHAVIOR	Generate monthly reports analyzing patterns in honeypot access attempts to improve	9 Months

	security controls and threat intelligence.	
--	--	--

 Data Source Solution #3		
Command Execution Honeypot (DS0017)	Difficulty: 3 (Hard) ▾	Priority: 3 (High) ▾
Deploy systems that appear to be legitimate servers but are actually isolated environments designed to trap attackers, monitor and record all command execution attempts, providing insights into attacker techniques while containing their activities.		
Addresses attack vector(s):	- T1059: Command and Scripting Interpreter- T1053: Scheduled Task/Job- T1569: System Services- T1204: User Execution	
STAKEHOLDERS		
Executives	IT Team	Legal
Command honeypots provide detailed attack playbooks that demonstrate actual techniques used against our infrastructure. This intelligence justifies security investments.	Implementation provides a controlled environment to study attack techniques without risking production systems. Delivers actionable intelligence for hardening systems..	Provides court-admissible evidence of malicious activity while demonstrating our adoption of advanced security standards.
GOALS		
Name	Description	Deadline
DEPLOY CONVINCING SERVER ENVIRONMENT	Create at least 3 honeypot servers that mimic production environments with realistic but isolated configurations that can safely capture attacker activities.	9 Months
CAPTURE COMPLETE ATTACK SEQUENCES	Set up complete activity logging to capture all commands, file access, and network activity for full analysis of attacker methods.	9 Months
GENERATE ACTIONABLE INTELLIGENCE	Produce bi-weekly reports on observed attack techniques that include specific remediation recommendations for production environments.	1 year



Data Source Solution #4

**File Modification Honeypot
(DS0022)**

Difficulty: 1 (Easy) ▾

Priority: 2 (Medium) ▾

Strategically place decoy files throughout the network that appear to contain valuable information (credentials, financial data, intellectual property) that are continuously monitored for any access or modification attempts.

Addresses attack vector(s):

- T1083: File and Directory Discovery- T1119: Automated Collection- T1530: Data from Cloud Storage- T1074: Data Staged

STAKEHOLDERS

Executives

IT Team

Legal

File honeypots provide immediate visibility into potential data theft attempts, allowing for quantifiable metrics on data security effectiveness. Demonstrates proactive data protection.

Deployment integrates with existing file integrity monitoring systems with minimal configuration. Provides clear indicators of compromise with near-zero false positives.

Provides clear proof of unauthorized access, strengthening our legal standing and supporting compliance requirements.

GOALS

Name

Description

Deadline

**DEPLOY STRATEGIC FILE
HONEYPOTS**

Place at least 20 honeypot files containing convincing but fake sensitive data across network shares, cloud storage, and local systems based on likely attacker search patterns.

6 Months

**ESTABLISH REAL-TIME
MONITORING**

Implement detection systems that alert security teams within 5 minutes of any honeypot file access or modification with detailed tracking of all interactions.

6 Months

MEASURE EFFECTIVENESS

Track and report monthly on honeypot triggers, analysis of attacker behavior, and security improvements implemented as a

9 Months

	result of intelligence gathered.	
--	----------------------------------	--



Mitigations



Preventive Mitigations:

 Preventive Mitigations:	1
M1018: User Account Management	2
STAKEHOLDERS	2
Executives	2
IT Team	2
Legal	2
GOALS	2
IMPLEMENT ROLE-BASED ACCESS	2
AUTOMATE ACCOUNT LIFECYCLE	2
CONDUCT QUARTERLY REVIEWS	2
M1036: Account Use Policies	3
STAKEHOLDERS	3
Executives	3
IT Team	3
Legal	3
GOALS	3
UPDATE AUTHENTICATION POLICY	3
IMPLEMENT TECHNICAL CONTROLS	3
MEASURE COMPLIANCE	3
M1041: Encrypt Sensitive Information	3
STAKEHOLDERS	4
Executives	4
IT Team	4
Legal	4
GOALS	4
CLASSIFY SENSITIVE DATA	4
DEPLOY ENCRYPTION INFRASTRUCTURE	4
VERIFY PROTECTION COVERAGE	4



Preventive Solution #1

M1018: User Account Management

Difficulty: 2 (Medium) ▾

Priority: 2 (Medium) ▾

Set up complete user account controls covering the entire lifecycle from creation to removal, with appropriate permissions based on job roles and regular audits to prevent unauthorized access and privileges.

Addresses attack vector(s):

- -T1078: Valid Accounts- T1531: Account Access Removal- T1098: Account Manipulation- T1136: Create Account

STAKEHOLDERS

Executives

IT Team

Legal

Reduces risk of data breaches through compromised accounts while demonstrating governance maturity to partners and regulators.

Provides a structured process for account lifecycle management that integrates with existing directory services and reduces help desk workload.

Demonstrates due diligence in access control that supports compliance with SOX, HIPAA, and other regulatory requirements for account management.

GOALS

Name

Description

Deadline

IMPLEMENT ROLE-BASED ACCESS

Define and implement role-based access control for all critical systems with standard profiles that match job functions.

6 Months

AUTOMATE ACCOUNT LIFECYCLE

Deploy automated account provisioning and de-provisioning tied to HR systems to ensure access is removed within 24 hours of termination.

9 Months

CONDUCT QUARTERLY REVIEWS

Establish quarterly access review process where managers verify and attest to appropriate access levels for their teams.

1 Year



Preventive Solution #2

M1036: Account Use Policies	Difficulty: 1 (Easy) ▾	Priority: 2 (Medium) ▾
Develop and enforce comprehensive account usage policies including password requirements, multi-factor authentication, account lockout thresholds, and session timeout controls to prevent unauthorized access.		
Addresses attack vector(s):	- T1110: Brute Force - T1556: Modify Authentication Process - T1212: Exploitation for Credential Access - T1552: Unsecured Credentials	
STAKEHOLDERS		
Executives	IT Team	Legal
Strengthens overall security posture with minimal budget impact while meeting board and investor expectations for basic security controls.	Creates clear standards that can be technically enforced through existing systems while reducing account-related support tickets.	Provides documented policies that demonstrate reasonable security measures in the event of litigation or regulatory review.
GOALS		
Name	Description	Deadline
UPDATE AUTHENTICATION POLICY	Develop and publish updated authentication policies that require strong passwords, MFA for sensitive systems, and clear lockout thresholds.	6 Months
IMPLEMENT TECHNICAL CONTROLS	Configure all corporate systems to enforce new policy requirements through technical controls and monitoring.	6 Months
MEASURE COMPLIANCE	Establish monthly reporting on policy compliance rates with a target of 95% adherence across all departments.	9 Months

 Preventive Solution #3		
M1041: Encrypt Sensitive Information	Difficulty: 3 (Hard) ▾	Priority: 3 (High) ▾
Implement end-to-end encryption for sensitive data both at rest and in transit across all corporate		

systems, cloud services, and communication channels to prevent unauthorized access even in the event of system compromise.		
Addresses attack vector(s):	- T1039: Data from Network Shared Drive- T1213: Data from Information Repositories- T1005: Data from Local System- T1048: Exfiltration Over Alternative Protocol	
STAKEHOLDERS		
Executives	IT Team	Legal
Provides the last line of defense against data breaches while meeting customer and partner expectations for data protection. Enables new business opportunities with security-conscious clients.	Requires significant implementation effort initially but provides a standardized framework for data protection that works across multiple platforms.	Significantly reduces liability exposure in breach scenarios and satisfies encryption requirements across multiple regulations including GDPR, CCPA, and industry standards.
GOALS		
Name	Description	Deadline
CLASSIFY SENSITIVE DATA	Complete data classification initiative identifying all sensitive information repositories and tagging data according to protection requirements.	6 Months
DEPLOY ENCRYPTION INFRASTRUCTURE	Implement key management systems and encryption standards for all sensitive data repositories with zero impact on critical business functions.	9 Months
VERIFY PROTECTION COVERAGE	Complete third-party assessment confirming 100% of identified sensitive data is protected by appropriate encryption controls.	1 year